

Magti Portal — Role Access Matrix

Complete list of who can do what. Four roles: operator, manager, content_admin, admin.

✓ = Full access text = Conditional / limited — = No access

1. Auth guards (security.py)

Every endpoint uses one of these guards. They decide which roles can enter.

Guard name	operator	manager	content admin	admin
get_current_user (any logged-in user)	✓	✓	✓	✓
get_current_manager_user	—	✓	—	✓
get_current_admin_user	—	—	✓	✓
get_current_system_admin_user	—	—	—	✓
require_permission(perm)	if in list	if in list	if in list	always

2. User management

What	operator	manager	content admin	admin
See own profile	✓	✓	✓	✓
Edit own name / phone	✓	✓	✓	✓
Change own password	✓	✓	✓	✓
List all users	—	—	—	✓
Create a new user	—	—	—	✓
Edit user role / dept / position	—	—	—	✓
Activate or deactivate a user	—	—	—	✓
Reset another user's password	—	—	—	✓
Set user permissions	—	—	—	✓
List group leaders	—	—	—	✓

3. News / announcements

What	operator	manager	content admin	admin
Read news list	own dept	own dept	✓	✓
Read single news item	own dept	own dept	✓	✓
Create news	—	—	✓	✓
Edit news	—	—	✓	✓
Delete news	—	—	✓	✓
See edit history	—	—	✓	✓
Restore old version	—	—	✓	✓

4. Articles (knowledge base)

What	operator	manager	content admin	admin
Browse articles	published own dept	published own dept	all statuses	all statuses
Read single article	published own dept	published own dept	✓	✓
Create article	—	—	✓	✓
Edit article	—	—	✓	✓
Delete article	—	—	✓	✓
Archive / unarchive	—	—	needs perm	always
Mark as verified	—	—	✓	✓
See edit history	—	—	✓	✓
Restore old version	—	—	✓	✓
Log a view	✓	✓	✓	✓
See related articles	own dept	own dept	✓	✓
Personal notes on article	✓	✓	✓	✓
Report an issue	✓	✓	✓	✓
See stale articles list	—	—	✓	✓

5. Categories

What	operator	manager	content admin	admin
List categories	✓	✓	✓	✓
Create category	—	—	✓	✓
Edit category	—	—	✓	✓
Delete category	—	—	✓	✓

6. Video instructions

What	operator	manager	content admin	admin
List videos	own dept active only	own dept active only	✓	✓
Log a view	✓	✓	✓	✓
Create video	—	—	✓	✓
Edit video	—	—	✓	✓
Delete video	—	—	✓	✓
Archive / unarchive	—	—	needs perm	always

7. Required readings (compliance)

What	operator	manager	content admin	admin
See my own assignments	✓	✓	✓	✓
Mark a reading as done	✓	✓	✓	✓
Assign a new required reading	—	—	✓	✓
Look up reading by item	—	—	✓	✓
Edit a required reading	—	—	✓	✓
Delete a required reading	—	—	✓	✓

8. Statistics, dashboards, and exports

What	operator	manager	content admin	admin
Global compliance stats (read / unread ratio)	—	—	✓	✓
Per-user reading progress (personal data)	—	—	—	✓
KPI counts (users, articles, readings, videos)	—	—	✓	✓
Daily login activity	—	—	✓	✓
Popular search terms	—	—	✓	✓
Failed search terms	—	—	✓	✓
Team stats (manager view)	—	own dept	—	all depts
Department stats dashboard	—	✓	—	✓

What	operator	manager	content admin	admin
Team drill-down by team ID	—	—	✓	✓
Critical operators list	—	—	✓	✓
Group user completion stats	—	—	✓	✓
CSV export (personal data)	—	—	—	✓
XLSX export (personal data)	—	—	—	✓
PDF export: readings	—	needs perm	needs perm	always
PDF export: team stats	—	needs perm	needs perm	always

Note: CSV and XLSX exports need admin role (they contain personal data). PDF exports use the reports.export permission — manager gets it by default, content_admin does not unless added manually.

9. Messaging and notifications

What	operator	manager	content admin	admin
Read own inbox	✓	✓	✓	✓
Send a message	—	own dept	—	anyone
Mark message as read	✓	✓	✓	✓
Delete a message	✓	✓	✓	✓
Broadcast to department (SSE)	—	—	✓	✓
Send compliance nudge	—	✓	✓	✓
Notification summary	✓	✓	✓	✓

10. Search, favorites, tags, teams, feedback, audit

What	operator	manager	content admin	admin
Search articles	own dept	own dept	all	all
Global search	own dept	own dept	all	all
Search history	✓	✓	✓	✓
Favorites (view / add / remove)	✓	✓	✓	✓
Tags list	✓	✓	✓	✓
Teams list	✓	✓	✓	✓
Create team	—	—	—	✓
View all feedback reports	—	—	✓	✓
Resolve / reject feedback	—	—	✓	✓
Audit logs	—	—	—	✓
Upload files	—	—	✓	✓
SSE event stream	✓	✓	✓	✓
Health check	no auth	no auth	no auth	no auth

11. Default permissions given to each role

These are set when a user is created. Admin can change them per user. The admin role always bypasses permission checks — it does not need any of these.

Permission	operator	manager	content admin	admin
articles.view	—	—	✓	✓
articles.edit	—	—	✓	✓
articles.publish	—	—	✓	✓
articles.archive	—	—	✓	✓
videos.archive	—	—	✓	✓
users.manage	—	—	—	✓
compliance.assign	—	—	✓	✓
reports.export	—	✓	—	✓

Key observations

User management is admin-only. Creating, editing, activating, deactivating users, resetting passwords, and setting permissions all need the admin role. No other role can touch user accounts.

Content work is shared between content_admin and admin. Both can create, edit, and delete articles, news, categories, and videos. Operators and managers cannot change any content.

Statistics are split by sensitivity. General stats (KPIs, compliance ratio, search analytics) are open to content_admin + admin. Per-user progress and data exports (CSV, XLSX) are admin-only because they contain personal data. Managers see only their own department's team stats.

Messaging has department walls. Managers can only message users in their own department. Admin can message anyone. Operators and content_admins cannot send messages at all.

The permission system is layered. On top of the four roles, there are named permissions (like reports.export, articles.archive) stored per user. Admin always bypasses these checks. Other roles need the permission in their list. Defaults are set at creation time but can be changed by admin later.

Operators have the smallest footprint. They can read content for their department, manage their own profile, mark readings as done, use favorites and notes, and search. Everything else is blocked.